7. Actividad 1 — Clasificación de los datos

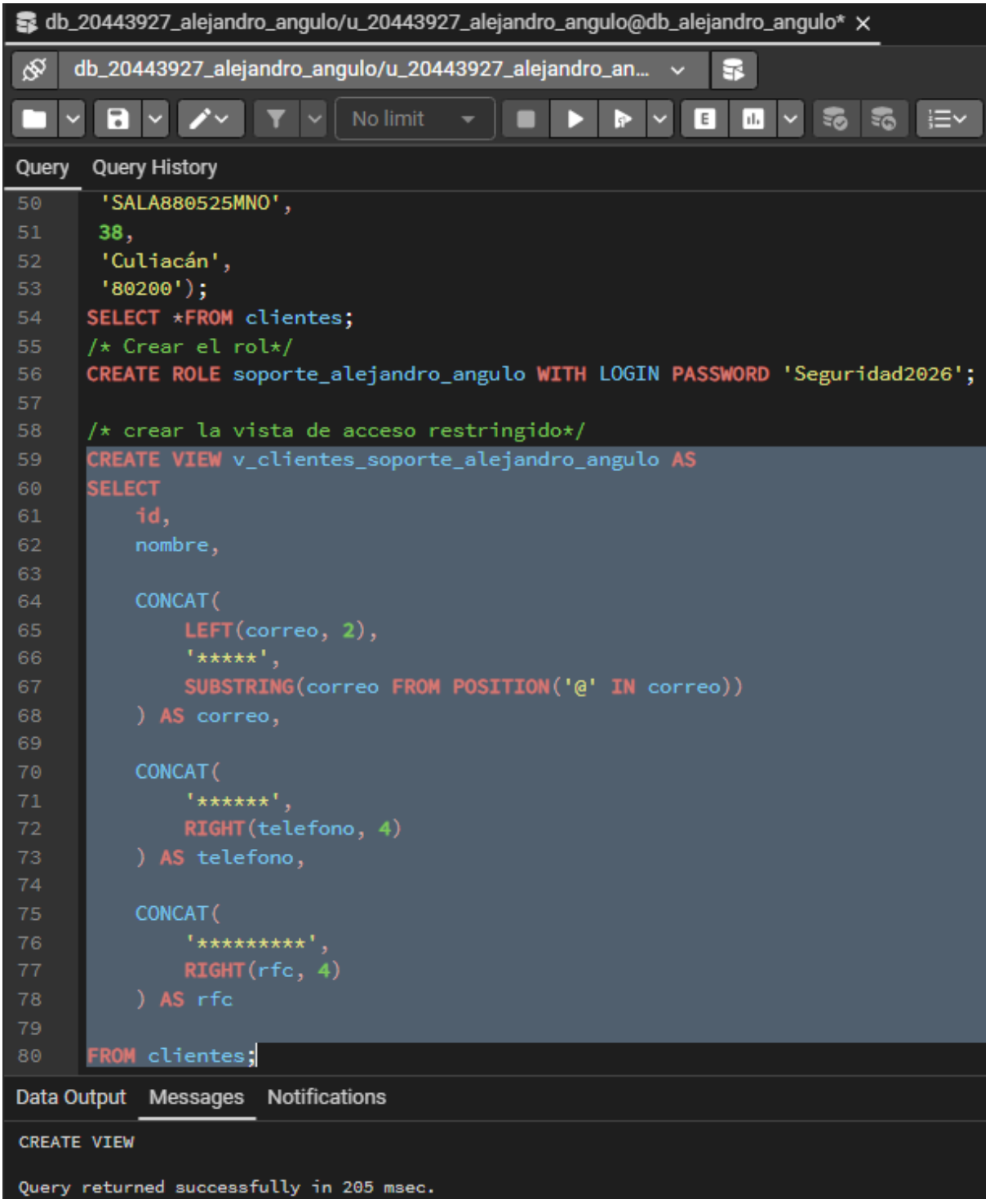
```
56    /* Crear el rol*/
57    CREATE ROLE soporte_alejandro_angulo WITH LOGIN PASSWORD 'Seguridad2026';
```

Data Output | Messages | Notifications

```
CREATE ROLE

Query returned successfully in 215 msec.
```

8.2 Crear una vista de acceso restringido



CONSULTAR LA VISTA:

```sql
/* Consultar la vista */
SELECT * FROM v_clientes_soporte_alejandro_angulo;
```

Data Output | Messages | Notifications

	id bigint	nombre character varying (120)	correo text	telefono text	rfc text
1	1	Ana López	an*****@example.t...	******45...	*********5ABC
2	2	Carlos Pérez	ca*****@example.t...	******56...	*********0DEF
3	3	María García	ma*****@example....	******67...	*********2GHI
4	4	Luis Torres	lu*****@example.t...	******78...	*********1JKL
5	5	Laura Sánchez	la*****@example.t...	******89...	*********5M...

8.3 Conceder acceso a la vista:

```sql
/* CONCEDER EL ACCESO */
GRANT USAGE
ON SCHEMA public
TO soporte_alejandro_angulo;
GRANT SELECT
ON v_clientes_soporte_alejandro_angulo
TO soporte_alejandro_angulo;
```

Data Output | Messages | Notifications

```
GRANT

Query returned successfully in 198 msec.
```

Revocar el acceso:

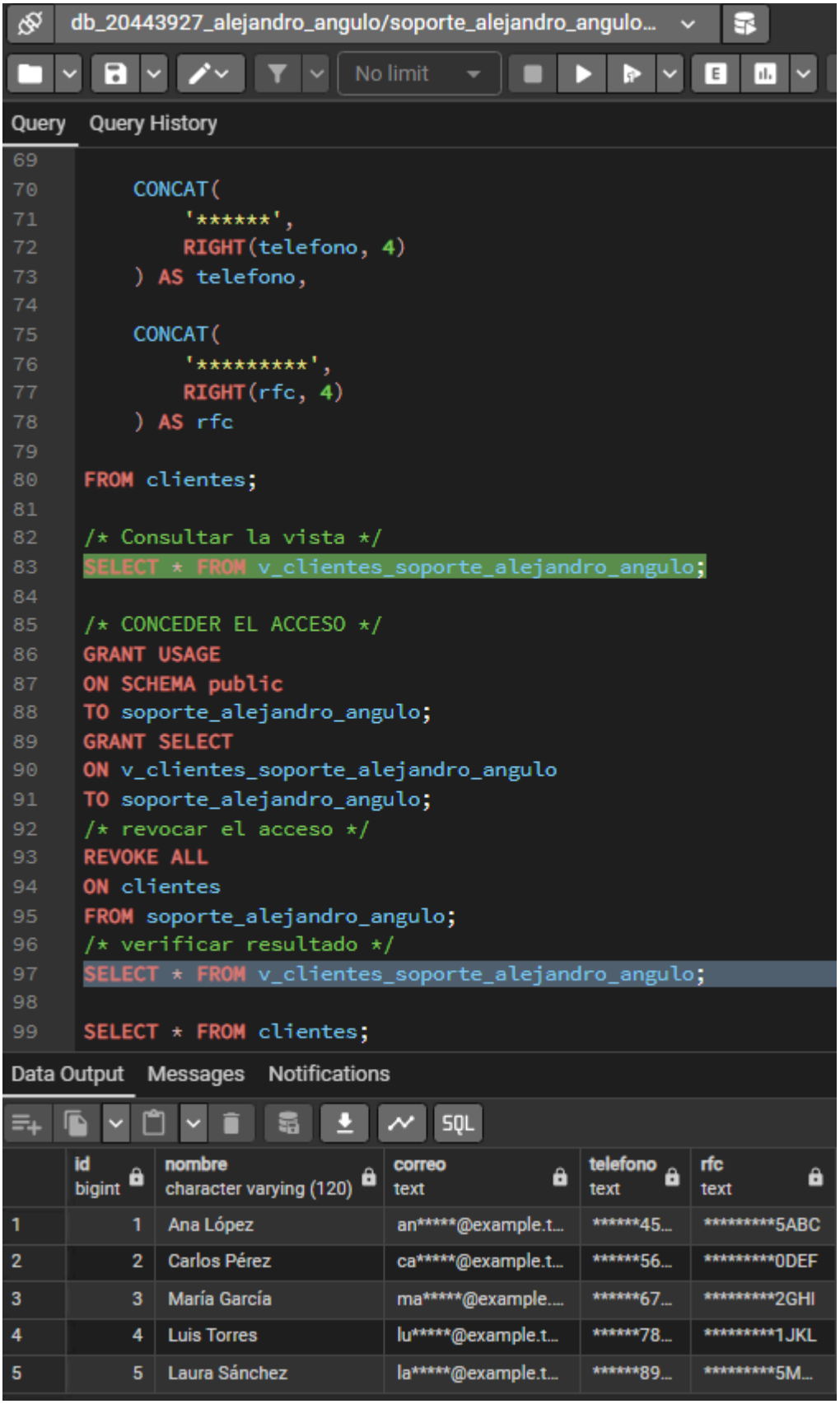
```sql
/* revocar el acceso */
REVOKE ALL
ON clientes
FROM soporte_alejandro_angulo;
```

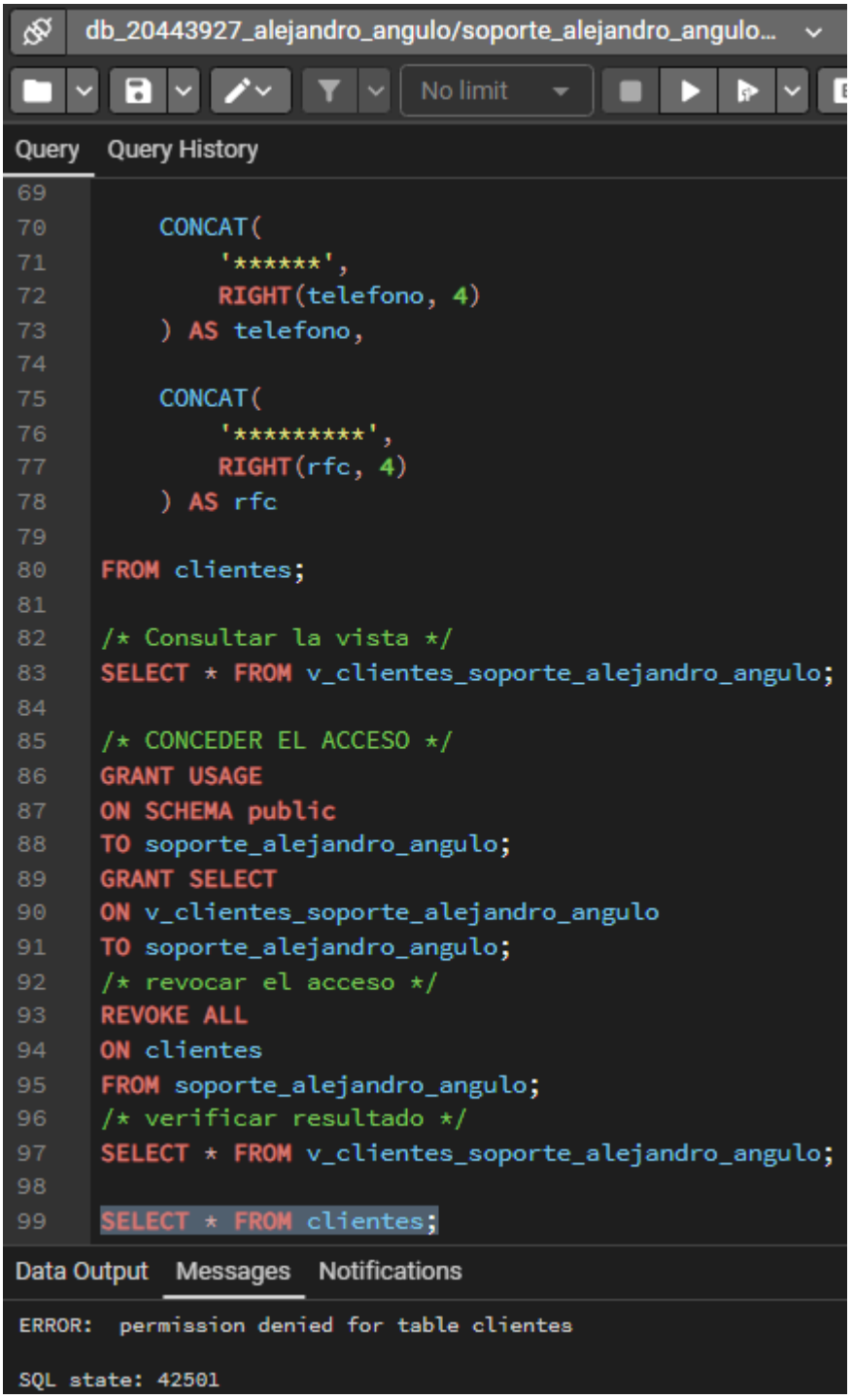
Data Output | Messages | Notifications

```
REVOKE

Query returned successfully in 218 msec.
```

8.4 Verificar el resultado


db_20443927_alejandro_angulo/soporte_alejandro_angulo...
No limit
Query
Query History
69
70 CONCAT(
71 '******',
72 RIGHT(telefono, 4)
73) AS telefono,
74
75 CONCAT(
76 '*********',
77 RIGHT(rfc, 4)
78) AS rfc
79
80 FROM clientes;
81
82 /* Consultar la vista */
83 SELECT * FROM v_clientes_soporte_alejandro_angulo;
84
85 /* CONCEDER EL ACCESO */
86 GRANT USAGE
87 ON SCHEMA public
88 TO soporte_alejandro_angulo;
89 GRANT SELECT
90 ON v_clientes_soporte_alejandro_angulo
91 TO soporte_alejandro_angulo;
92 /* revocar el acceso */
93 REVOKE ALL
94 ON clientes
95 FROM soporte_alejandro_angulo;
96 /* verificar resultado */
97 SELECT * FROM v_clientes_soporte_alejandro_angulo;
98
99 SELECT * FROM clientes;
Data Output
Messages
Notifications
SQL
id bigint
nombre character varying (120)
correo text
telefono text
rfc text
1 1 Ana López an*****@example.t... ******45... *********5ABC
2 2 Carlos Pérez ca*****@example.t... ******56... *********0DEF
3 3 María García ma*****@example.... ******67... *********2GHI
4 4 Luis Torres lu*****@example.t... ******78... *********1JKL
5 5 Laura Sánchez la*****@example.t... ******89... *********5M...



1. ¿Qué información continúa existiendo en la tabla original?

Toda. La vista no modifica, copia ni borra nada: es solo una consulta guardada. En clientes siguen completos:

correo, teléfono y rfc sin enmascarar.
Los campos que la vista ni siquiera expone: edad, ciudad, codigo_postal y fecha_alta.

2. ¿Qué información puede visualizar el usuario soporte?
Por los permisos otorgados, soporte puede:
Ver el esquema public .
Consultar v_clientes_soporte, y por tanto ver: id, nombre completo, las dos primeras letras del correo con su dominio, los últimos 4 dígitos del teléfono y los últimos 4 caracteres del RFC.
No puede ver edad, ciudad, codigo_postal, fecha_alta ni los valores completos de correo, teléfono o RFC.

3.¿Por qué no es suficiente ocultar los datos únicamente en la aplicación?

Porque la aplicación es solo una de las vías de acceso a la base de datos, y la restricción vive en la capa equivocada:
Otras vías de acceso: quien tenga credenciales de la base puede conectarse con psql, DBeaver, scripts, herramientas de BI o reportes y saltarse por completo la aplicación.
Los datos viajan completos: si el enmascaramiento ocurre en el frontend o en el backend, la base ya entregó los datos reales. Basta con inspeccionar el tráfico de red, la respuesta de la API, los logs o la memoria para verlos.
Fallas y vulnerabilidades: un error de programación, una inyección SQL, un endpoint olvidado o un cambio de código pueden exponer la información sin enmascarar.
Principio de defensa en profundidad: la seguridad no debe depender de un único control. La base de datos debe aplicar mínimo privilegio por sí misma.
4. ¿Qué ocurriría si el soporte tuviera acceso directo a clientes?
Podría ejecutar SELECT * FROM clientes y ver correo, teléfono y RFC completos, además de edad, ciudad, codigo_postal y fecha_alta.
La vista sería decorativa: nadie estaría obligado a usarla.
Con el RFC completo (que revela fecha de nacimiento) y los datos de contacto, aumentaría el riesgo de fraude, suplantación de identidad, acoso y fuga de información.
Si además tuviera UPDATE o DELETE, podría alterar o borrar datos, con riesgo para la integridad.

Se incumpliría el principio de mínimo privilegio y el de proporcionalidad: soporte solo necesita datos suficientes para identificar y atender al cliente.
Ante una brecha o un uso indebido, la organización tendría mayor responsabilidad por no haber aplicado medidas técnicas razonables.